

TRILHA CLF-C02 · PILAR 4 DE 7

Segurança e Conformidade

Quem pode o quê, como se protege e onde termina a responsabilidade da AWS

7 SERVIÇOS · CICLO 2 · 2026/2

OS 56 SERVIÇOS DA TRILHA

Você está aqui



1 CATEGORIA ACESA · 7 SERVIÇOS NESTA AULA

DOMÍNIO 3 DO EXAME · 34% DA PROVA

O ROTEIRO DE HOJE

O domínio que vale 30% da prova

Segurança e Conformidade é o **maior domínio do CLF-C02**. E, diferente dos outros pilares, aqui não basta saber o que cada serviço faz: a prova cobra **onde termina a AWS e começa você**.

Sete serviços

IAM, KMS, Cognito, AWS WAF, Secrets Manager, Shield e GuardDuty.

Responsabilidade Compartilhada

O modelo que atravessa todo o exame. Segurança **da** nuvem contra segurança **na** nuvem.

Prevenir e detectar

Duas categorias diferentes de serviço, e a prova separa uma da outra o tempo todo.

A cola e o simulado

Tabela comparativa dos sete serviços, as pegadinhas clássicas e 5 questões no estilo da prova.

Atenção à sigla: **AWS WAF** é um dos serviços de hoje. O **Well-Architected Framework**, que usa a mesma sigla, tem um deck só dele: o pilar 7.

ANTES DE COMEÇAR · A SIGLA QUE CONFUNDE

"WAF" quer dizer duas coisas diferentes

AWS WAF



Web Application Firewall

- É um **serviço** que você contrata e configura
- Filtra requisições HTTP por regra: SQL injection, XSS, bot, IP
- Fica acoplado ao CloudFront, ao ALB ou ao API Gateway
- Cobra por regra e por milhão de requisições inspecionadas
- Aparece na Tabela Periódica, entre os serviços de segurança

≠

WELL-ARCHITECTED FRAMEWORK



O framework de arquitetura

- É um **documento**, não um serviço: não se contrata
- Seis pilares para avaliar qualquer arquitetura na AWS
- Não tem preço nenhum: é conhecimento publicado pela AWS
- Não aparece na Tabela Periódica, porque não é serviço
- **Tem um deck inteiro só dele: o pilar 7**

Na prova, o contexto separa: se a alternativa fala em **bloquear requisição**, é o serviço, e é dele que este deck trata. Se fala em **avaliar a arquitetura**, é o framework, no pilar 7.

CONCEITO-BASE Nº 1 · O MAIS COBRADO DO EXAME INTEIRO

Segurança da nuvem e segurança na nuvem

CLIENTE · SEGURANÇA NA NUVEM

- Seus dados
- Quem acessa (IAM)
- Sistema operacional
- Firewall e rede
- Criptografia dos dados

Configuração, código, patch do que você instala, e quem tem qual permissão.

A LINHA QUE A PROVA COBRA

AWS · SEGURANÇA DA NUVEM

- Hardware e servidores
- Virtualização
- Rede física
- Datacenter e acesso físico
- Regiões e AZs

A infraestrutura que roda tudo. Você nunca vai ter acesso a esta camada, e nem precisa.

CONCEITO-BASE Nº 2 · O DETALHE QUE SEPARA QUEM ESTUDOU

A linha se move conforme o serviço

SERVIÇO	MODELO	QUEM FAZ O PATCH DO SO	O QUE CONTINUA SENDO SEU
Amazon EC2	IaaS	**Você**	SO, aplicação, dados, firewall, IAM, criptografia
Amazon RDS	Gerenciado	**A AWS**	Schema, queries, quem tem senha, criptografia
AWS Fargate	Contêiner sem servidor	**A AWS**	A imagem do contêiner, a task role, a aplicação
AWS Lambda	Serverless	**A AWS**	O código, a execution role, as dependências
Amazon S3	Serviço gerenciado	**A AWS**	Quem pode abrir o bucket, e o que você guarda nele

Note o que **nunca** sai da sua coluna, em nenhuma linha: **os dados e o controle de acesso**. Isso é sempre do cliente, em todo serviço da AWS.

PARTE 1 · OS SETE SERVIÇOS

Segurança



SEGURANÇA · SERVIÇO 1 DE 7



AWS IAM

IDENTITY AND ACCESS MANAGEMENT

Quem é você e o que pode fazer. O serviço que responde a essas duas perguntas em toda a AWS.

PREÇO aws.amazon.com/iam DOCUMENTAÇÃO docs.aws.amazon.com/iam CALCULADORA calculator.aws

AWS IAM · IDENTITY AND ACCESS MANAGEMENT

Quem é você, e o que você pode fazer



É o **crachá com as portas liberadas**. Toda chamada na AWS passa por aqui: o IAM confere a identidade e olha a lista de permissões antes de deixar qualquer coisa acontecer.

Users

Uma pessoa ou aplicação com credencial própria. Cada um tem o seu, nunca compartilhe.

Groups

Conjunto de usuários que recebem as mesmas permissões. Grupo não tem credencial.

Roles

Permissão **temporária** que alguém assume, a forma correta de dar acesso a uma EC2 ou Lambda.

Policies

O documento JSON que diz o que é permitido. É ele que se anexa a user, group ou role.

Três regras que a prova cobra direto: **menor privilégio · MFA na conta root · nunca usar a root no dia a dia**, e nunca gerar chave de acesso para ela.

AWS IAM · A BOA PRÁTICA QUE VIRA QUESTÃO

Nunca coloque uma chave dentro do código

ERRADO · CHAVE NO CÓDIGO



A chave vaza junto com o repositório,
nunca expira e ninguém sabe quem a usou.

CERTO · IAM ROLE NA INSTÂNCIA



Credencial **temporária**, rotacionada sozinha,
sem nada gravado em lugar nenhum.

Se a alternativa disser "criar um usuário IAM e guardar a chave na aplicação", **ela está errada**.

SEGURANÇA

Menor privilégio, MFA obrigatório na root, roles em vez de chaves, e credencial rotacionada. **O IAM é a fronteira da responsabilidade, controle de acesso é sempre do cliente.**

PRECIFICAÇÃO

O IAM é totalmente gratuito. Não há custo por usuário, por role, por política nem por chamada. É de graça e é obrigatório usar bem.

NO EXAME

"Menor privilégio", "MFA", "role em vez de chave", "não usar a root" → **IAM**. É global, não tem região. **Não cai** escrever policy em JSON.

SEGURANÇA · SERVIÇO 2 DE 7



AWS KMS

KEY MANAGEMENT SERVICE

Cria e guarda as chaves de criptografia da conta, e registra cada uso delas.

PREÇO aws.amazon.com/kms/pricing DOCUMENTAÇÃO docs.aws.amazon.com/kms CALCULADORA calculator.aws

AWS KMS · KEY MANAGEMENT SERVICE

O cofre das chaves que abrem os seus dados



Criptografar é fácil; o difícil é **guardar a chave**. O KMS é o cofre central: a chave nunca sai dele em texto claro, e cada uso fica **registrado no CloudTrail**.

Integrado em tudo

S3, EBS, RDS, DynamoDB, Lambda, Secrets Manager: todos criptografam com chave do KMS.

Gerenciada ou sua

A AWS pode gerenciar a chave por você, ou você cria a sua e controla quem pode usá-la.

Rotação automática

A chave pode ser trocada periodicamente sem que nada na aplicação precise mudar.

SEGURANÇA

A chave é gerada e usada dentro de módulos de hardware validados; **nunca sai em texto claro**. Quem pode usá-la é definido por política de chave e por IAM.

PRECIFICAÇÃO

Por **chave gerenciada por mês** + por 10 mil requisições de criptografia. Chave esquecida continua cobrando o mês inteiro. Chaves gerenciadas pela AWS não têm custo mensal.

NO EXAME

"Gerenciar chaves de criptografia", "controlar quem descriptografa" → **KMS**. Confunde com **Secrets Manager**, que guarda *senha*, não chave criptográfica.

SEGURANÇA · SERVIÇO 3 DE 7



Amazon Cognito

IDENTIDADE DOS SEUS USUÁRIOS

Cadastro, login e token para os usuários da sua aplicação, não para quem administra a conta.

PREÇO aws.amazon.com/cognito/pricing DOCUMENTAÇÃO docs.aws.amazon.com/cognito CALCULADORA calculator.aws

AMAZON COGNITO

O login dos seus usuários, não o dos seus administradores



O IAM cuida de **quem trabalha na empresa** e mexe na conta AWS. O Cognito cuida de **quem usa o seu aplicativo**: os milhões de clientes que só querem entrar e comprar.

Cadastro e login prontos

Tela de cadastro, confirmação por e-mail, recuperação de senha e MFA, sem você escrever nada.

Login social e corporativo

Entrar com Google, Apple, Facebook ou com o SAML da empresa, sem código de integração.

Token para a API

Emite o token que o API Gateway valida, é assim que ele protege a sua API.

SEGURANÇA

Senhas com hash, MFA, política de complexidade e bloqueio por tentativa. Emite token padrão OAuth e OIDC. **A AWS opera o diretório; o fluxo do seu app é seu.**

PRECIFICAÇÃO

Por **usuário ativo no mês**: quem não entrou não conta. Free tier mensal generoso; recursos avançados de segurança são cobrados à parte.

NO EXAME

"Login dos usuários do aplicativo", "cadastro", "entrar com Google" → **Cognito**. Se for acesso a recursos da AWS, é **IAM**. Essa é a distinção cobrada.

SEGURANÇA · SERVIÇO 4 DE 7



AWS WAF

WEB APPLICATION FIREWALL

Filtra o tráfego HTTP por regra: bloqueia SQL injection, XSS, bot e IP indesejado.

PREÇO aws.amazon.com/waf/pricing DOCUMENTAÇÃO docs.aws.amazon.com/waf CALCULADORA calculator.aws

AWS WAF · WEB APPLICATION FIREWALL

O segurança na porta, lendo cada requisição



Enquanto o security group olha só **de onde vem o pacote**, o WAF **abre a requisição HTTP e lê o conteúdo**, e barra a que carrega uma tentativa de injeção de SQL.

Regras gerenciadas

Conjuntos prontos da AWS e de parceiros cobrem o OWASP Top 10 sem você escrever regra.

Bot e rate limiting

Bloqueia robô de raspagem e limita quantas requisições um mesmo IP faz por minuto.

Onde ele mora

Acopla-se ao CloudFront, ao Application Load Balancer ou ao API Gateway. Nunca fica sozinho.

SEGURANÇA

Atua na **camada 7**, onde o security group não alcança. Protege contra SQL injection, XSS, bot e abuso de taxa. **As regras são escolha sua.**

PRECIFICAÇÃO

Por **web ACL por mês** + por regra + por milhão de requisições inspecionadas. Conjuntos gerenciados de parceiros custam à parte.

NO EXAME

"SQL injection", "XSS", "bloquear bot", "filtrar requisição HTTP" → **AWS WAF**. Não confundir com o **Well-Architected Framework**.

SEGURANÇA · SERVIÇO 5 DE 7



AWS Secrets Manager

COFRE DE SEGREDOS

Guarda senha, token e chave de API fora do código, e rotaciona sozinho no prazo que você definir.

PREÇO aws.amazon.com/secrets-manager/pricing

DOCUMENTAÇÃO docs.aws.amazon.com/secretsmanager

CALCULADORA calculator.aws

AWS SECRETS MANAGER

A senha do banco sai do arquivo de configuração



Em vez do post-it com a senha colado no monitor, um **cofre que entrega a senha na hora do uso**, e que **troca a senha sozinho** a cada 30 dias, avisando o banco junto.

Rotação automática

É o diferencial: ele troca a credencial no cofre **e no RDS**, sem intervenção humana.

Recuperada em execução

A aplicação pede o segredo quando precisa. Nada fica gravado em imagem, código ou variável.

Alternativa mais barata

O Parameter Store, do Systems Manager, guarda segredo de graça, mas **não rotaciona sozinho**.

SEGURANÇA

Criptografado com KMS, acesso por IAM, e cada leitura registrada no CloudTrail. **Tira do seu repositório a categoria de erro mais comum em vazamento.**

PRECIFICAÇÃO

Por **segredo por mês** + por 10 mil chamadas de API. **Sem free tier permanente**: por isso muita gente usa o Parameter Store quando não precisa de rotação.

NO EXAME

"Rotacionar credencial automaticamente", "senha fora do código" → **Secrets Manager**. Se falar em *chave de criptografia*, a resposta é KMS.

SEGURANÇA · SERVIÇO 6 DE 7



AWS Shield

PROTEÇÃO CONTRA DDOS

Absorve ataques de negação de serviço na borda da rede. O nível Standard já vem ligado, de graça.

PREÇO aws.amazon.com/shield/pricing DOCUMENTAÇÃO docs.aws.amazon.com/waf CALCULADORA calculator.aws

AWS SHIELD

Contra DDoS, e já está ligado



> Um ataque DDoS é uma **multidão fingindo ser cliente** para entupir a porta. O Shield absorve essa massa **na borda da rede da AWS**, antes de ela chegar em você.

SHIELD STANDARD

Grátis e automático

- **Já está ativo** em toda conta AWS, sem configurar nada
- Cobre os ataques comuns de camada de rede e transporte
- Protege CloudFront, Route 53 e Load Balancer por padrão
- Custo: **zero**

SHIELD ADVANCED

Assinatura para quem é alvo

- Detecção mais fina e relatórios detalhados de ataque
- Acesso ao time de resposta a incidentes da AWS
- **Proteção de custo**: a AWS devolve o gasto causado pelo ataque
- Assinatura mensal alta, com compromisso de longo prazo

SEGURANÇA

Atua nas camadas 3 e 4, na borda. Para ataque na camada 7 (requisição HTTP legítima em massa) o instrumento é o **AWS WAF**, junto com ele.

PRECIFICAÇÃO

Standard é gratuito e já vem ligado. Advanced é assinatura mensal com compromisso de 1 ano, é a resposta quando o enunciado fala em custo alto de proteção.

NO EXAME

"Proteção DDoS já incluída, sem custo" → **Shield Standard**. "Time de resposta e proteção de custo" → **Advanced**. Essa distinção cai bastante.

SEGURANÇA · SERVIÇO 7 DE 7



Amazon GuardDuty

DETECÇÃO DE AMEAÇAS

Lê os logs da conta o tempo todo e avisa quando o comportamento parece invasão.

PREÇO aws.amazon.com/guardduty/pricing DOCUMENTAÇÃO docs.aws.amazon.com/guardduty CALCULADORA calculator.aws

AMAZON GUARDDUTY

O alarme que percebe comportamento estranho



Ele lê os logs da conta o tempo todo procurando o que **não parece normal**: uma credencial usada de um país onde ninguém trabalha, uma instância conversando com um endereço conhecido por mineração de criptomoeda.

Liga com um clique

Não instala agente nem muda a arquitetura. Ele lê CloudTrail, VPC Flow Logs e DNS logs.

Detecta, não bloqueia

Ele gera um achado com severidade. Reagir é com você, geralmente via EventBridge e Lambda.

Os vizinhos dele

Inspector procura vulnerabilidade no software. **Macie** procura dado pessoal no S3.

SEGURANÇA

É **detecção**, não prevenção. Complementa o WAF e o Shield, que bloqueiam. A AWS opera a inteligência de ameaças; agir sobre o achado é seu.

PRECIFICAÇÃO

Por volume de log analisado, quanto mais movimento na conta, mais custa. **30 dias de teste gratuito**, com estimativa de custo antes de você decidir manter.

NO EXAME

"Detectar atividade maliciosa ou anômala" → **GuardDuty**. "Vulnerabilidade em software" → Inspector. "Dado sensível no S3" → Macie.



PARTE 2 · QUANDO NÃO É UMA CONTA SÓ

Governança e conformidade

Nenhuma empresa de verdade roda em uma conta AWS só. E o exame cobra o que aparece quando são **dezenas de contas**: quem controla, quem paga e quem audita.

AWS ORGANIZATIONS

Muitas contas, uma fatura e um teto de permissão

> Cada time com a **sua conta** é a boa prática, isola falha, isola custo, isola acesso. O Organizations é o **prédio** que junta todas essas salas sob a mesma administração.

Faturamento consolidado

Uma fatura só para a empresa inteira, e o **volume somado** destrava desconto por uso que conta isolada não alcança.

Unidades organizacionais

As OUs agrupam contas por time, ambiente ou área, e recebem política em bloco.

SCPs

Service Control Policies definem o **teto** do que uma conta pode fazer, "nenhuma conta deste grupo cria recurso fora de São Paulo".

Custo zero

O Organizations é **gratuito**. Você paga apenas o uso das contas que ele agrupa.

SEGURANÇA

A SCP **não concede permissão**: ela limita. Mesmo um administrador da conta-filha não passa do teto que a SCP define. É o instrumento de guarda-corpo da organização.

PRECIFICAÇÃO

Gratuito. O ganho financeiro vem do faturamento consolidado: descontos por volume e Reserved Instances compartilhadas entre as contas.

NO EXAME

"Várias contas", "uma fatura só", "aplicar política a todas as contas" → **Organizations**. SCP **restringe**; IAM **concede**.

EM CIMA DO ORGANIZATIONS

Montar e entrar em dezenas de contas

AWS CONTROL TOWER



A planta baixa multi-conta

- Cria a **landing zone**: a estrutura inicial de contas já organizada
- Aplica **guardrails** prontos, obrigatórios ou recomendados
- Tem uma fábrica de contas: nova conta nasce já dentro das regras
- É construído **sobre o Organizations**, não substitui

+

IAM IDENTITY CENTER



Um login para todas elas

- Login único para **várias contas AWS** e para aplicações SaaS
- Integra com Active Directory, Okta, Entra ID
- Acaba com o usuário IAM criado conta a conta
- Era chamado de **AWS SSO**: material antigo usa esse nome

Repare na divisão: **Organizations** agrupa e limita · **Control Tower** monta e vigia · **Identity Center** resolve quem entra.



AWS ARTIFACT · CONFORMIDADE

"Me manda o relatório de auditoria da AWS"

Em algum momento o auditor ou o cliente vai pedir a comprovação de que a AWS cumpre ISO 27001, SOC 2 ou PCI DSS. Esse documento **não se pede ao suporte**: ele está no console, para baixar na hora.

Relatórios de conformidade

SOC 1, 2 e 3, ISO, PCI DSS, e os laudos regionais. Autoatendimento e **gratuito**.

Acordos

É onde se aceita o adendo de processamento de dados, quando a LGPD ou o GDPR exigem.

Só o lado da AWS

Ele prova a conformidade **da infraestrutura**. A conformidade da **sua** aplicação continua sendo sua.

É a Responsabilidade Compartilhada aparecendo de novo: o Artifact entrega o certificado do datacenter. Se o auditor perguntar quem tem acesso aos seus dados, a resposta está no IAM e no CloudTrail.

DETECÇÃO · QUATRO SERVIÇOS QUE A PROVA TROCA ENTRE SI

Cada um procura uma coisa diferente

GUARDDUTY

Comportamento

Lê os logs da conta e acha o que é estranho.

"credencial usada de outro país"

INSPECTOR

Vulnerabilidade

Varre EC2, imagem de contêiner e Lambda.

"esta biblioteca tem uma CVE conhecida"

MACIE

Dado sensível

Descobre dado pessoal dentro do S3.

"tem CPF neste bucket que ninguém sabia"

SECURITY HUB

O painel único

Junta os achados dos três e checa padrões.

"quero uma tela só com tudo"

Os quatro **detectam**. Nenhum deles bloqueia, quem bloqueia é IAM, WAF, Shield e security group.



AWS CERTIFICATE MANAGER · ACM

O cadeado do navegador, renovado sozinho

Certificado público grátis

Emite o certificado TLS do seu domínio sem custo, para usar dentro da AWS.

Renovação automática

Acaba com o incidente clássico de site fora do ar porque o certificado venceu no domingo.

Onde ele encaixa

No **CloudFront**, no **Application Load Balancer** e no **API Gateway**. A chave privada nunca sai do serviço.

No exame: "certificado SSL/TLS gerenciado e renovado automaticamente" → **ACM**. É gratuito para certificado público usado em serviços integrados da AWS.

COLA · OS SETE SERVIÇOS DE SEGURANÇA

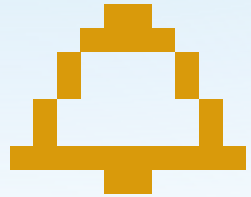
Cada um protege uma coisa diferente

SERVIÇO	PROTEGE	PREVINE OU DETECTA	COMO COBRA	PALAVRA-CHAVE NO ENUNCIADO
 AWS IAM	Acesso à conta AWS	Previne	**Gratuito**	menor privilégio, MFA, role, root
 AWS KMS	As chaves de criptografia	Previne	Por chave/mês + requisições	gerenciar chave, criptografar em repouso
 Amazon Cognito	O login do seu app	Previne	Por usuário ativo no mês	cadastro, login social, token do usuário final
 AWS WAF	A aplicação web (camada 7)	Previne	Por ACL, regra e requisição	SQL injection, XSS, bot, filtrar HTTP
 Secrets Manager	Senhas e tokens	Previne	Por segredo/mês + chamadas	rotação automática, senha fora do código
 AWS Shield	A borda, contra DDoS	Previne	**Standard grátis**; Advanced assinatura	DDoS, proteção já incluída
 Amazon GuardDuty	A conta, lendo logs	**Detecta**	Por volume de log analisado	atividade maliciosa, comportamento anômalo

Os dois **gratuitos** (IAM e Shield Standard) são justamente os que mais aparecem na prova.

O QUE DERRUBA CANDIDATO

Pegadinhas clássicas (1 de 2)



AWS WAF E WELL-ARCHITECTED

✗ "A questão fala em WAF, então é sobre os seis pilares."	✓ São coisas distintas. **AWS WAF é firewall de aplicação**, um serviço pago. **Well-Architected é um framework**, um documento com seis pilares.

IAM E COGNITO

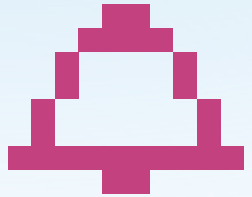
✗ "Vou criar um usuário IAM para cada cliente do aplicativo."	✓ IAM é para **quem administra a conta AWS**. Usuário final do seu app é **Cognito**, e escala para milhões, o que o IAM não faz.

O PATCH DO SISTEMA OPERACIONAL

✗ "A AWS cuida da segurança, então ela atualiza meu servidor."	✓ Numa **EC2, o patch do SO é seu**. A AWS só assume isso em serviços gerenciados como RDS, Lambda e Fargate. A linha se move conforme o serviço.

O QUE DERRUBA CANDIDATO

Pegadinhas clássicas (2 de 2)



KMS E SECRETS MANAGER

✗ "Preciso guardar a senha do banco: vou usar o KMS."	✓ KMS guarda **chave de criptografia**. Senha, token e chave de API vão para o **Secrets Manager**, que ainda rotaciona sozinho.

GUARDDUTY BLOQUEANDO

✗ "Liguei o GuardDuty, então os ataques serão bloqueados."	✓ GuardDuty **detecta e avisa**. Quem bloqueia é o WAF, o Shield ou o security group. Detecção e prevenção são categorias diferentes na prova.

PAGAR PELO SHIELD

✗ "Para ter proteção contra DDoS preciso contratar o Shield."	✓ O **Shield Standard já está ativo em toda conta, de graça**. Só o Advanced é assinatura, e ele existe para quem é alvo frequente.

Questões

QUESTÃO 1 DE 5 · ESTILO CLF-C02

Quem atualiza o sistema operacional?

Uma empresa roda a aplicação em instâncias **Amazon EC2**. Segundo o Modelo de Responsabilidade Compartilhada, quem é responsável por **aplicar as atualizações de segurança do sistema operacional convidado**?

A) A AWS, porque opera a infraestrutura

B) O cliente

C) É dividido igualmente entre AWS e cliente

D) O parceiro AWS que vendeu a conta

QUESTÃO 1 DE 5 · GABARITO

Quem atualiza o sistema operacional?

Uma empresa roda a aplicação em instâncias **Amazon EC2**. Segundo o Modelo de Responsabilidade Compartilhada, quem é responsável por **aplicar as atualizações de segurança do sistema operacional convidado**?

A) A AWS, porque opera a infraestrutura

B) O cliente

C) É dividido igualmente entre AWS e cliente

D) O parceiro AWS que vendeu a conta

GABARITO COMENTADO

B · O cliente

Em **EC2**, tudo do sistema operacional para cima é do cliente. A AWS responde pelo hipervisor, pelo hardware e pelo datacenter: a chamada **segurança *da* nuvem**.

Cuidado com a troca: se a pergunta fosse sobre **RDS, Lambda ou Fargate**, a resposta viraria "a AWS". O serviço muda a linha, e é justamente isso que a prova testa.

QUESTÃO 2 DE 5 · ESTILO CLF-C02

Milhões de usuários no aplicativo

Um aplicativo de delivery precisa oferecer **cadastro, login e recuperação de senha** para milhões de clientes, com opção de entrar usando conta Google. Qual serviço a AWS oferece para isso?

A) AWS IAM, criando um usuário para cada cliente

B) Amazon Cognito

C) AWS Secrets Manager

D) AWS Directory Service

QUESTÃO 2 DE 5 · GABARITO

Milhões de usuários no aplicativo

Um aplicativo de delivery precisa oferecer **cadastro, login e recuperação de senha** para milhões de clientes, com opção de entrar usando conta Google. Qual serviço a AWS oferece para isso?

A) AWS IAM, criando um usuário para cada cliente

B) Amazon Cognito

C) AWS Secrets Manager

D) AWS Directory Service

GABARITO COMENTADO

B · Amazon Cognito

Usuário **final do aplicativo** é sempre Cognito: cadastro, login, recuperação de senha e federação com Google ou Apple, escalando para milhões.

Por que as outras caem: A: IAM é para quem administra a conta AWS, e não escala para milhões de clientes. **C:** guarda segredo de aplicação, não identidade de usuário. **D:** integra Active Directory corporativo, não o público do app.

QUESTÃO 3 DE 5 · ESTILO CLF-C02

Tentativas de SQL injection

O time de segurança identificou tentativas de **SQL injection e cross-site scripting** contra o site da empresa, que roda atrás de um Application Load Balancer. Qual serviço bloqueia esse tipo de requisição?

A) Security groups mais restritivos

B) AWS WAF acoplado ao balanceador

C) Amazon GuardDuty

D) AWS Shield Standard

QUESTÃO 3 DE 5 · GABARITO

Tentativas de SQL injection

O time de segurança identificou tentativas de **SQL injection e cross-site scripting** contra o site da empresa, que roda atrás de um Application Load Balancer. Qual serviço bloqueia esse tipo de requisição?

A) Security groups mais restritivos

B) AWS WAF acoplado ao balanceador

C) Amazon GuardDuty

D) AWS Shield Standard

GABARITO COMENTADO

B · AWS WAF

SQL injection e XSS vivem **dentro do conteúdo da requisição HTTP**. Só um firewall de camada 7 lê esse conteúdo e decide bloquear, e ele acopla no ALB, no CloudFront ou no API Gateway.

Por que as outras caem: A: security group filtra por IP e porta, e não enxerga o corpo da requisição. **C:** GuardDuty detecta e avisa, não bloqueia. **D:** Shield trata DDoS, nas camadas 3 e 4.

QUESTÃO 4 DE 5 · ESTILO CLF-C02

Uma credencial usada de outro país

A empresa quer ser **avisada automaticamente** quando houver comportamento suspeito na conta, uma credencial usada de um país onde ninguém trabalha, ou uma instância conversando com endereço conhecido por mineração. Qual serviço faz isso?

A) AWS Shield Advanced

B) Amazon GuardDuty

C) AWS WAF

D) AWS KMS

QUESTÃO 4 DE 5 · GABARITO

Uma credencial usada de outro país

A empresa quer ser **avisada automaticamente** quando houver comportamento suspeito na conta, uma credencial usada de um país onde ninguém trabalha, ou uma instância conversando com endereço conhecido por mineração. Qual serviço faz isso?

A) AWS Shield Advanced

B) Amazon GuardDuty

C) AWS WAF

D) AWS KMS

GABARITO COMENTADO

B · Amazon GuardDuty

As palavras **comportamento suspeito** e **avisar** colocam a questão na categoria de **detecção**. O GuardDuty lê CloudTrail, Flow Logs e DNS logs e gera achados com severidade.

Por que as outras caem: A, **C** e **D** são serviços de **prevenção**: bloqueiam DDoS, filtram requisição HTTP e guardam chave. Nenhum deles vigia o comportamento da conta.

QUESTÃO 5 DE 5 · ESTILO CLF-C02

A senha do banco no código-fonte

Uma auditoria encontrou a **senha do banco de dados escrita no código-fonte**. A empresa quer tirá-la de lá e ainda **trocá-la automaticamente a cada 30 dias**. Qual serviço atende os dois pontos?

A) AWS KMS

B) AWS Secrets Manager

C) AWS IAM

D) Amazon Cognito

QUESTÃO 5 DE 5 · GABARITO

A senha do banco no código-fonte

Uma auditoria encontrou a **senha do banco de dados escrita no código-fonte**. A empresa quer tirá-la de lá e ainda **trocá-la automaticamente a cada 30 dias**. Qual serviço atende os dois pontos?

A) AWS KMS

B) AWS Secrets Manager

C) AWS IAM

D) Amazon Cognito

GABARITO COMENTADO

B · AWS Secrets Manager

Duas exigências: guardar o segredo fora do código **e** rotacioná-lo sozinho. A **rotação automática** é justamente o que separa o Secrets Manager do Parameter Store.

Por que as outras caem: A: KMS guarda chave de criptografia, não senha de banco. **C:** IAM controla acesso a recursos AWS, e o banco tem credencial própria. **D:** Cognito cuida do usuário final do aplicativo.

UMA PÁGINA PARA REVISAR ANTES DO EXAME

FlashCards

AWS IAM
Users, groups, roles, policies. Menor privilégio, MFA na root, role em vez de chave. Gratuito e global.

AWS KMS
Cofre das chaves de criptografia. Integrado a S3, EBS, RDS. Cobra por chave/mês.

Amazon Cognito
Login do usuário final do app, com social e MFA. Cobra por usuário ativo no mês.

AWS WAF
Firewall de camada 7 contra SQL injection, XSS e bot. Acopla em CloudFront, ALB ou API Gateway.

Secrets Manager
Senha e token fora do código, com rotação automática. É a rotação que o diferencia.

AWS Shield
Anti-DDoS na borda. Standard é grátis e já ligado; Advanced é assinatura com resposta a incidente.

GuardDuty
Lê logs e detecta comportamento anômalo. Detecta e avisa, não bloqueia.

Responsabilidade
AWS: segurança **da** nuvem. Cliente: segurança **na** nuvem. Dados e acesso são sempre seus.

Root e MFA
Nunca use a root no dia a dia, nunca gere chave de acesso para ela, e ligue MFA nela hoje.

Role × chave
Credencial temporária que rotaciona sozinha × chave gravada no código, que vaza no repositório.

WAF × WAF
AWS WAF é firewall de aplicação. Well-Architected é framework, e tem deck próprio no pilar 7.

Detectar × prevenir
GuardDuty, Inspector e Macie detectam. IAM, WAF, Shield e security group previnem.

Regra de ouro do pilar: **a linha da responsabilidade se move conforme o serviço, mas os dados e o controle de acesso nunca saem do lado do cliente · prevenir ≠ detectar.**

PARA LEVAR DAQUI

Onde continuar depois da aula

Controlar o custo

Antes de subir qualquer recurso, simule na calculadora. Depois de subir, olhe o billing toda semana e ligue um alarme de orçamento.

CALCULADORA calculator.aws

BILLING console.aws.amazon.com/billing

FREE TIER aws.amazon.com/pt/free

Estudar com a AWS

O Skill Builder tem a trilha oficial do CLF-C02. O Builder Center é o hub da comunidade: use o link exclusivo da nossa liga ao se cadastrar.

SKILL BUILDER skillbuilder.aws

BUILDER CENTER · LIGA bit.ly/3U5ayCy

EXAME CLF-C02 aws.amazon.com/pt/certification/…

Acompanhar a liga

A agenda dos encontros vive no Meetup. O material de cada aula, incluindo estes slides, fica no GitHub da liga.

MEETUP meetup.com/aws-sbg-pucrs

SITE liganuvem.com

INSTAGRAM @liganuvem.pucrs

Todo preço citado neste deck é **referência de us-east-1** e envelhece. A calculadora é a fonte confiável na hora de dimensionar de verdade.



TRILHA CLF-C02 · PILAR 4 DE 7

Segurança e Conformidade

Quem pode o quê, como se protege e onde termina a responsabilidade da AWS

7 SERVIÇOS · CICLO 2 · 2026/2